

청렴실천, 나로부터 시작됩니다

정보보안업무예규 위반 관련
복 무 감 사 결 과

2017. 7.

 **NPS** 국민연금공단 감사

I . 감사 개요

□ 배경

- 2017. 6. 5.(월) 「정보보안조사위원회」의 감사의뢰와 관련하여, ◇◇◇◇◇실 소속 ○○○의 규정 위반 여부 및 공단의 비인가 프로그램 차단 대책의 실효성 등에 대해 감사를 실시함

« 「정보보안조사위원회」 의결 요지 »

업무와 무관한 비인가 프로그램을 업무용 PC에 설치하고, 이를 통해 보안정책상 접속이 차단된 외부 상용메일 사이트에 접속한 행위는 중대한 사안으로 '감사의뢰 처분'을 의결함

□ 감사 기간 및 인원

- (기간) 2017. 6. 7.(수)~6. 16.(금) <8일간>
- (인원) 4명

□ 감사 대상

- ◇◇◇◇◇실 ○○○(기간제 근로자), 해당 관리자 등
- ▲▲▲본부 담당직원 등

□ 감사 방법

- (◇◇◇◇◇실) PC 및 인터넷 등 로그기록 확인, 대상자 문답 등
- (▲▲▲본부) 관련자 문답 및 현장 확인 등(비인가 프로그램·악성코드 등 차단 및 방역 시스템 운영 현황 등)

Ⅱ. 감사결과 처분요구 명세

경고 · 부서주의 요구

【 1 】

제 목 : 비인가 프로그램 사용 등에 관한 사항
구 분 : 보안관리 등
내 용

1. 확인된 사실

가. 비인가 프로그램 '토르 브라우저'(Tor Browser¹) 사용 및 탐지 경위

2017. 5. 18. 14:59 ◇◇◇◇◇실 소속 기간제 근로자 ○○○(이하 '○○○'이라 함)은 한신대 ●●● 교수로부터 '2차 시범사업 결과에 대한 원시 데이터(raw data)'를 부탁하는 웹메일을 수신했고,

같은 날 15:35 경 이 메일을 수신한 ○○○은 ●●● 교수가 요청한 자료가 본인의 PC에 저장되어 있는지 또는 소속 팀 직원이 갖고 있는 자료인지 확인하였으나 이를 발견할 수 없게 되자, 종전에 본인 ■■■메일 계정으로 발송해둔 자료 중 같은 자료가 있는지 확인하기 위해 17:33에 인터넷 망에서 토르(Tor Browser)를 실행하였다.

1) IP 주소 추적·탐지를 회피하여 익명으로 차단된 사이트에 접속할 수 있는 인터넷 우회 접속 프로그램. 가상 컴퓨터와 네트워크를 여러 차례 경유하면서 사용자의 인터넷 접속 흔적을 추적할 수 없게 함. 차단된 사이트를 익명으로 방문할 수 있어 감시와 검열의 자유 지대이자 범죄의 온상으로도 불림. 발신자도 밝히지 않고 데이터를 전송할 수 있어 네트워크 감시나 트래픽 분석, 위치 추적 등을 어렵게 만드는 특징이 있음

* 토르 브라우저는 비인가 프로그램으로 이를 이용하면 공단에서 보안정책상 접속을 차단하고 있는 상용메일, 주식거래 및 음란 등의 사이트에 추적을 회피하여 익명으로 접속할 수 있음

《 ○○○의 토르 실행 현황 》

일자	시작시간	종료시간	총 사용시간
2017. 5. 18.	17:33:22	18:01:51	00:28:19

그러나, 토르의 로딩 속도가 늦어져 ■■■메일 계정에 접속하지 못하게 되자(○○○의 진술2), ○○○은 직접 자료를 작성하여 17:42 경3) 공단 메신저(NPS messenger)를 이용해 같은 팀 ▲▲▲ 대리에게 작성한 자료를 보내 ●●● 교수에게 이메일로 발송해줄 것을 요청한 후 18:01에 토르를 종료하였다.

한편, 당시는 전 세계적으로 랜섬웨어4) 및 그 변종이 확산되어 사이버 위기가 ‘관심’에서 ‘주의’ 단계로 상향된 상황으로 공단은 ▲▲▲본부 주관 하에 자체 보안관계 및 모니터링을 강화하고 있었고, ○○○이 2017. 5. 18. 17:33에 토르를 실행하자 17: 41 공단 사이버위협관리시스템(TMS, Threat Management System)에서 최초로 랜섬웨어로 의심되는 통신 트래픽을 탐지하였다.

▲▲▲본부에서는 같은 날 17:55 해당 통신 트래픽은 랜섬웨어 감염에 의한 것이 아닌 것으로 확인하고, 18:12 해당 통신 트래픽 발신자인 ○○○에게 전화하여 랜섬웨어 감염 증상 유무 등을 확인한 후 19:01 ○○○으로부터 본인이 사용했던 ‘인터넷 우회 접속 프로그램’ 파일을 공단 웹메일로 제출받아 해당 통신 트래픽이 토르로 인한 것이었음을 최종 확인하였다.

2) 전산자료 확인 결과, ○○○의 토르 실행 시간(5. 18. 17:33~18:01)에 인터넷 망에서 다운로드한 자료는 없는 것을 확인함

3) ○○○은 메신저 대화기능을 이용해 ▲▲▲ 대리에게 자료를 보냈기 때문에 정확한 시간을 확인할 수는 없으나, 같은 시간에 ●●● 교수가 메일로 보내준 ‘의료쪽 신체활동 기능 로직.hwp’이라는 자료를 팀 소속 직원 전원에게 전자우편으로 발송했기 때문에 전자우편 발송시간인 17:42 경이 맞다고 진술함

또한, 17:33에 토르를 실행한 후 17:42에 작성을 완료해서 ●●● 교수에게 발송할 것을 요청했다면 요청받은 자료를 채 10분도 안되는 시간에 작성이 가능한지에 대해서는, ‘새롭게 자료를 작성하는 것이 아니라 기존의 자료를 확인해서 다시 보내주는 정도였다.’고 답변함

4) Ransomware, 시스템을 잠그거나 데이터를 암호화해 사용하지 못하도록 한 뒤, 이를 풀어주는 대가로 금전을 요구하는 악성 프로그램

나. 토르 브라우저(Tor Browser) 입수 경위 및 이용 현황

감사실에서 ○○○이 주로 사용하는 외부 상용메일 계정(■■■■메일 및 △메일)을 확인한 결과⁵⁾, ○○○은 2015. 9. 22. 최초로 토르 프로그램을 본인의 공단 웹메일 계정에서 본인의 외부 상용메일인 △메일과 ■■■■메일 계정으로 발송한 사실이 확인되었고,

이는 ○○○이 감사 문답에서 ‘2015. 9월 경 IT를 전공하는 친구가 토르를 쓰면 공단에서도 상용메일 접속이 가능하다고 알려줬고 그 친구에게서 공단 웹메일을 통해 받았다.’는 진술에서 밝힌 최초 입수시기와 일치한다.

토르의 사용 횟수와 관련해서, ○○○은 ‘필요한 경우에만 썼기 때문에 주 또는 월 단위로 사용 횟수를 추정할 수는 없고 대략적으로 1년에 10회 미만으로 사용한 것 같다.’고 답변하였다.

그러나, 감사실에서 2017. 2월 기간제 근로자로 재계약된 이후 2017. 5월까지 3개월간 ○○○의 토르 실행이력을 확인한 바에 따르면, ○○○은 인터넷 망에서 본인의 웹메일 편지보관함에 저장된 토르 파일을 다운로드하여 실행(2회)하거나 업무용 PC에 저장된 토르 파일을 인터넷 망으로 전송하여 실행(5회)시키는 방법으로 아래에서 보는 바와 같이 총 7회 실행한 사실이 확인되었다.⁶⁾

《 ○○○의 토르 실행 현황(2017. 2월~5월) 》

연번	일자	시작시간	종료시간	사용시간	실행방법
1	2017. 3. 22.(수)	09:06:54	12:10:33	3:03:39	PC에서 인터넷 망으로 전송
2	2017. 3. 24.(금)	08:45:48	12:55:32	4:09:44	웹메일에서 다운로드
3	2017. 4. 4.(화)	13:11:46	18:02:45	4:50:59	웹메일에서 다운로드

5) 감사실은 감사 목적으로 수집하고자 하는 정보·자료에 대해 ○○○에게 설명한 후 ‘전산매체 수집 및 이용 동의서’를 받은 후(2017. 6. 9.) 조사를 진행함

6) 현재 공단 본부의 전산환경은 논리적 망분리 상태로, 인터넷에 접속하기 위해서는 가상의 인터넷 망에 접속해야 하며 접속을 종료하면 인터넷 망이 초기화되어 인터넷 망에 설치된 프로그램이 삭제됨. 따라서 토르를 실행하기 위해서는 매번 토르 프로그램을 인터넷 망으로 전송한 후 재설치해야 함

연번	일자	시작시간	종료시간	사용시간	실행방법
4	2017. 4. 5.(수)	11:13:16	13:14:38	2:01:22	웹메일에서 다운로드
5	2017. 4. 11.(화)	22:23:35	익일 03:14:47)	4:51:09	웹메일에서 다운로드
6	2017. 4. 17.(월)	17:47:11	17:55:08	0:07:57	웹메일에서 다운로드
7	2017. 5. 18.(목)	17:33:32	18:01:51	0:28:19	PC에서 인터넷 망으로 전송

즉, ○○○은 2015. 9. 22. 친구에게서 처음 토르 프로그램을 공단 웹메일로 전송받아 업무용 PC에 저장하는 한편 두 개의 본인 상용메일 계정으로도 발송하여 해당 파일을 백업해 두었으며, 이후 2017. 5. 18. 랜섬웨어로 탐지되어 본인이 해당 파일을 삭제할 때까지 약 20개월 간 토르를 사용했고,

2017. 2월~5월까지 3개월간 총 7회 토르 프로그램을 실행한 것으로 보아 연평균 28회 가량 사용한 것으로 볼 수 있고, 7회 동안 총 19시간33분 동안 실행하여 1회당 평균 사용시간은 2시간47분 가량인 것으로 추정된다.

한편, 토르 사용 목적과 관련하여, ○○○은 '퇴근 후 또는 출장 중에도 수시로 ▣부 등에서 자료제출을 요구하는 경우가 많아 언제라도 업무자료에 접근해야 했는데 공단 웹메일은 접속이 안 되는 경우가 있어 본인 상용메일 계정에까지 자료를 발송해 둔 것이며, 보내놓은 자료를 찾아보기 위해 △메일 계정 등에 접속하는 경우에만 토르를 사용했고 토르를 이용해 다른 사이트에 접속한 적은 없다.'고 진술했다.⁸⁾

다. 개인정보 보호 및 관리에 관한 사항

감사실에서는 ○○○의 개인정보 유출 여부를 확인하기 위해 업무용 PC 내

- 7) ○○○은 2017. 4. 11.(화)에 22:23~익일 03:14까지 총 4시간51분간 토르를 실행한 것에 대해 '4. 17.(월)에 예정된 복지코디 대상 교육용 업무매뉴얼 제작을 위해 밤샘 근무할 때 실행시켜둔 것'이라고 진술했고, 감사실에서 확인한 결과 4. 17.(월)에 지사 담당자 19명을 대상으로 대전 KT인재개발원에서 '장애등급제 개편 3차 시범사업 업무담당자 합동교육'을 실시한 바 있음
- 8) ○○○이 상용메일 계정 접속 외 토르를 이용해 타 사이트에 접속했는지 여부는 IP 주소의 추적 및 탐지를 회피하는 토르의 프로그램 속성 상 이를 확인할 수는 없음

보관 자료, 공단 웹메일⁹⁾ 및 개인 상용메일(△메일, ■■■메일)¹⁰⁾ 송·수신 내역을 점검하였다.

먼저, ○○○의 업무용 PC 내 보관 자료를 점검한 결과, 2017. 6. 7. 현재 업무용 PC 내 전체 12,819개 파일 중 ●개 파일에 ‘주민번호, 외국인번호, 이메일 및 핸드폰번호’ 유형의 개인정보가 포함되어 있음에도 암호화 등의 보안조치가 없었음이 확인되었고,

○○○의 공단 웹메일 발송내역(2016. 7월 ~ 2017. 5월)을 확인한 결과, ☆차례에 걸쳐 ‘성명, 생년월일, 주소, 전화번호, 휴대전화번호, 장애등급’ 등 개인정보가 포함된 엑셀파일을 첨부 하여 ○○○ 본인의 공단 웹메일 계정과 2개의 본인 상용메일 계정으로 발송한 후, 이를 본인의 노트북 PC에 저장(추후 삭제함*)한 사실이 확인되었다.

* ○○○은 상기 개인정보 파일을 노트북 PC에 저장하여 자료분석 등의 작업 후 다시 본인의 공단 웹메일 및 상용메일 계정으로 발송하고 노트북 PC 내 파일은 삭제하였다고 진술하였고, 2017. 6. 15. ○○○의 노트북 PC 점검결과, 개인정보 파일이 노트북 PC에 보관되어 있지 않음을 확인함

한편, ○○○은 2014. 4월부터 매년 기간제 근로자로 채용되어 ◇◇◇◇◇실에 근무했으나, 각 연도별로 계약기간이 종료되어 다음 해에 다시 채용될 때까지 고용이 단절된 기간에도 계약기간 중 업무상 취득했던 개인정보 파일을 본인의 상용메일 계정(△메일, ■■■메일)에 보관한 사실이 확인되었다.

9) 2017. 6. 13. ○○○의 공단 웹메일 발송함을 확인한 결과, 2016. 7. 7.부터 2017. 5. 18.까지 242건의 메일이 ○○○의 공단 웹메일 또는 상용메일 계정 등으로 발송된 사실을 확인함.

* 2016. 7월 전 기록은 ○○○의 이전 공단 웹메일 계정이 삭제되어 확인이 불가하였음

10) 2017. 6. 9. ○○○의 상용메일 수신함을 확인한 결과, 2014년 재직 시부터 공단 웹메일을 통해 ■■■메일로 598건, △메일로 431건의 자료를 발송하여 수신·보관중인 것을 확인함

《 ○○○의 기간제 근로자 고용기간 》

연번	연도	고용(계약) 기간	고용 단절기간	비고
1	2014년	4. 22. ~ 11. 30.	11. 31. ~ 12. 31.	○○○은 각 연도별 고용(계약) 기간 종료 후 다음 연도에 다시 채용될 때까지 '비상근 자문위원' 등으로 같은 업무를 수행함 ¹¹⁾
2	2015년	1. 20. ~ 12. 31.	1. 1. ~ 1. 19.	
3	2016년	7. 1. ~ 12. 30.	1. 1. ~ 3. 30.	
4	2017년	2. 13. ~ 12. 29.	1. 1. ~ 2. 12.	-

라. 기간제 근로자에 대한 관리·감독에 관한 사항

「개인정보보호법」 제28조(개인정보취급자에 대한 감독), 「표준 개인정보보호 지침」 제15조(개인정보취급자에 대한 감독)에 따르면, 공단은 기간제 근로자를 포함한 전 임직원에게 보안서약서를 제출하도록 해야 하며 정기적으로 필요한 교육을 실시하는 등 적절한 관리·감독을 해야 하고,

이와 관련하여, 가입지원실(개인정보보호부)은 외부인력을 포함하여 인력을 신규로 채용하는 경우 ‘공단에서 승인받지 않은 프로그램은 공단 내에서 사용하지 않겠다.’는 내용과 개인정보 보호 의무와 책임을 명시한 ‘개인정보 보안서약서’를 작성하도록 하고 있다.

그럼에도, ◇◇◇◇◇실에서는 ○○○을 2014년부터 2017년까지 총 4회에 걸쳐 기간제 근로자로 채용하면서도 2015년을 제외하고는 ‘개인정보 보안서약서’ 작성 및 정구를 누락(3회)하였으며,

개인정보 보호 교육과 관련해서, ○○○은 ‘교육을 전혀 받은 적이 없었다. 동영상 시청하라고 공지를 받은 적은 있었으나 틀어놓는 수준이었다.’, ‘주민등록번호나 여권번호만 없으면 개인정보에 문제가 없다고 생각했다.’고 진술하는

11) 장애인서비스지원팀-394호(2014.12.23.) “장애판정도구 검토회의 및 자문료지급 계획(안)”
 장애인서비스지원팀-5호(2016.1.8.) “장애등급제 개편 2차 시범사업을 위한 연구지원 계획(안)”
 장애인서비스지원팀-555호(2016.12.28.) “장애등급제 개편 3차 시범사업을 위한 연구지원 계획(안)”

등, 소속 부서인 ◇◇◇◇◇실에서 기간제 근로자 등에 대한 개인정보 보호 교육을 실효성 있게 시행하지 않고 있음을 확인할 수 있었다.

또한, 개인정보보호부-685호(2015. 6. 16.) “「개인정보보호의 날」행사 개선 계획 통보”에 따라, 공단 전 직원은 개인별 PC 내 개인정보 파일의 암호화 조치·파기 여부를 주기적으로 점검하여 그 결과를 공단 전산망인 NPIS에 등록해야 하며, 외부인력(기간제 근로자 포함)의 개인정보 파일은 개인정보보호 분임담당자(3급 이하 직원)가 점검한 후 그 결과를 등록하여야 한다.

그러나, 앞서 언급한 바와 같이 ○○○이 2017. 6. 7. 현재 본인의 업무용 PC에 ●개에 이르는 개인정보 파일을 암호화조치 없이 보관하고 있었는데도, ◇◇◇◇◇실 개인정보보호 분임담당자인 ◎급 ●●●은 이에 대한 확인 없이 2017. 3월부터 ○○○의 개인정보 파일 관리실태가 걱정된 것으로 등록·보고하였다.

한편, 공단은 「정보보안업무예규」에 PC의 자료를 인터넷 망으로 전송하는 경우 결재권자의 사전 또는 사후 승인을 받도록 규정하고 있으며, 여기서 ‘승인’이란 단순한 행정상의 절차에 불과한 것이 아니라 인터넷 망으로 전송되는 자료의 내용 및 목적 등을 확인하여 통제한다는 의미를 포함하는 것으로 보아야 한다.

그러나, ◇◇◇◇◇실 ▲급 ◇◇◇은 ○○○이 2017. 2. 24.부터 5. 18.까지¹²⁾ 총 76건의 업무자료를 ○○○ 본인의 업무용 PC에서 인터넷 망으로 전송하기 위해 승인을 요청했음에도 2017. 5. 24. 현재까지 15건은 승인하지 않은 상태로 방치¹³⁾하였고,

○○○이 공단 개인정보가 포함된 파일과 토르의 압축파일(파일명 : exe변경1.zip)을 업무용 PC에서 인터넷 망으로 전송하기 위해 그 사유를 ‘업무목적 등’으로 기재하여 승인 요청했으나, 이에 대한 적정 여부를 확인하지 아니한 채 해당 파일 반출을 승인한 바 있다.

12) 공단 파일전송시스템은 최근 3개월까지만 전송내역을 확인할 수 있음

13) 승인대기 중인 경우에도 자료전송은 가능함

《 공단 개인정보 전송 승인 현황 》

연번	파일명	승인요청일시	승인자	승인방법	사유	비고
1	★3차시범사업관련.zip	2017-05-04 9:02	◇◇◇	사후승인	업무목적 등	개인정보 포함
2	★3차시범사업관련(2).zip	2017-05-04 9:02	◇◇◇	사후승인	업무목적 등	

《 토르(파일명 : exe변경1.zip) 전송 승인 현황 》

연번	파일명	승인요청일시	승인자	승인방법	사유
1	exe변경1.zip	2017-03-13 15:27	◇◇◇	사후승인	업무목적 등
2	exe변경1.zip	2017-03-21 9:16	◇◇◇	사후승인	업무목적 등
3	exe변경1.zip	2017-03-22 8:43	◇◇◇	사후승인	업무목적 등
4	exe변경1.zip	2017-03-22 13:29	◇◇◇	사후승인	업무목적 등
5	exe변경1.zip	2017-05-18 17:22	◇◇◇	사후승인	업무관련 자료 송수신

2. 문제점

가. 기간제 근로자 ○○○

공단이 비인가 프로그램의 설치·사용과 상용메일 사용을 금지하는 이유는 전 국민을 대상으로 연금제도 및 각종 복지제도를 운영함에 따라 공단이 보유하고 있는 방대한 양의 개인정보를 보호하고, 동시에 비인가 프로그램 및 상용메일을 매개로 한 악성코드의 유입 등 사이버 위협에 대응하여 공단 정보자산의 안정성을 확보하고자 하는 것이다.

이를 위해 공단은 「정보보안업무예규」 등 내부지침을 마련하여 시행하고 있고, 특별히 주의해야할 사항은 2015년 이후에만 총 3회에 걸쳐 전 부서에 문서를 시행¹⁴⁾하여 안내하면서 ‘향후 상용메일 무단 사용 등 위규 발생시 보안 위규

14) ■■■■부-665(2015. 9. 16.) ‘보안취약 프로그램 사용금지 안내’,
 ■■■■부-283(2016. 2. 2.) ‘공단 내 상용메일 사용 금지 및 웹 메일 보안 준수사항 재안내’
 ■■■■부-1690(2016. 7. 22.) ‘비인가(업무외) 프로그램 및 불법 소프트웨어 사용금지 안내’

처리기준에 의거 엄중 처분'할 것임을 공지한 바 있다.

따라서, 공단 전산망을 사용하는 모든 사용자는 그 고용형태와 관계없이 공단의 규정·지침을 준수해야 하며, 이는 기간제 근로자라고 해서 달리 볼 이유가 없는 것이다.

그럼에도 불구하고, ○○○은 2015. 9. 22. 비인가 프로그램인 토르를 친구로부터 전해 받은 후 2017. 5. 18. 탐지될 때까지 약 20개월간 △메일, ■■■메일 등 외부 상용메일 접속을 목적으로 사용한 사실이 확인되었고, 이는 「정보보안업무예규」 제25조(PC등 단말기 보안관리), 제26조(인터넷PC 보안관리), 제34조(전자우편 보안대책), 제36조(악성코드 감염 방지대책) 등을 각각 위반한 것이다.

또한, ○○○은 본인의 업무용 PC에 ●개에 이르는 개인정보 파일을 암호화 조치 없이 보관하고 있었고, 수차례 개인정보 파일을 본인의 공단 웹메일 계정과 상용메일 계정으로 발송·수신하여 개인 노트북 PC에 저장(추후 삭제한 사실을 확인함)하는 한편, 기간제 근로자로서의 근무 단절기간에도 상기의 개인정보 파일을 본인의 상용메일 계정에 보관해 온 사실이 있다.

비록 ○○○의 이러한 행위가 개인정보의 무단 제공 또는 유출을 금지한 「개인정보보호법」 제59조 및 「표준개인정보보호지침」 제25조 등을 위반했다고 볼 수는 없다 하더라도,

○○○은 본인의 업무 특성상 보유하고 있는 PC 내 개인정보에 대해, 개인정보 보호 및 유출사고 방지를 위하여 해당 파일을 암호화하여 보관하고 보유목적이 끝난 파일은 전수 파기하는 등의 조치를 취해야 하는데도 이를 이행하지 아니한 것이며,

공단이 보유한 개인정보를 취급할 때에는 최소한 공단의 각종 안전조치가 미치는 범위 내에 있어야 하므로 공단에 등록된 PC 등에 보관하여 관리하여야 함에도, 개인정보가 포함된 자료를 「정보보안업무예규」 등에 따른 보안정책이 반

영되어 있지 않은 개인 노트북 PC에 다운로드하여 사용한 것은 해킹 등 외부로부터의 침해위험에 그대로 노출시킨 것으로 볼 수 있다.

아울러, 공단 보안정책상 접근이 차단된 상용메일에 공단 개인정보 파일을 송·수신한 후 해당 파일을 상용메일 계정에 보관함으로써 해당 정보가 외부로 유출될 수 있는 위험에 노출시키는 등, ○○○의 행위는 「내부관리계획」 제10조, 「개인정보보호규정」 제34조, 「정보보안업무예규」 제34조 제3항을 위반한 것임이 분명하다.

다만, ○○○이 토르를 사용한 목적이 종전의 업무자료를 찾거나 퇴근 후 또는 출장 중 등 사무실 외의 공간에서 본인 상용메일에 접속하여 업무를 수행하기 위한 것이었고, 이 과정에서 공단 개인정보가 제3자에게 유출된 정황을 발견할 수 없었다는 점, 그리고 최근 3개월 간 7회 토르를 실행한 것으로 보아 업무자료 검색 목적으로 상용메일 접속한 것 외에 지속적으로 주식·도박·게임 등의 사이트에 접속했다고는 볼 수 없는 점,

아울러, ○○○은 기간제 근로자로서 개인정보 보호 등을 위한 공단의 보안 규정 등에 대해 보다 각별한 교육과 통제가 필요한데도 이를 소홀히 한 것에 대해서는 소속부서(◇◇◇◇◇실)의 책임이 크다는 점 등을 전반적으로 고려할 필요가 있다.

나. ◇◇◇◇◇실

○○○이 소속된 ◇◇◇◇◇실은 개인정보처리자로서 「개인정보보호법」 제28조(개인정보취급자에 대한 감독) 및 「표준개인정보보호지침」 제15조(개인정보취급자에 대한 감독)에 따라, 개인정보취급자인 ○○○에 대해 적절한 관리·감독을 행하여야 하는데도,

2014년부터 2017년까지 총 4회에 걸쳐 ○○○을 기간제 근로자로 채용하면서도 2015년을 제외하고는 ‘개인정보 보안서약서’ 작성·징구를 누락했고, 기간제

근로자에 대한 개인정보보호 교육 등이 형식에 그쳐 실질적으로 이루어지지 않은 사실이 확인되었다.

또한, 개인정보보호부-685호(2015. 6. 16.) “「개인정보보호의 날」행사 개선 계획 통보”에 따라 매월 개인정보보호 분임담당자는 외부인력에 대해 개인정보 파일 보유 및 적정 관리 여부를 직접 확인한 후 이를 공단 전산(NPIS)에 등록하여야 하는데도, ◇◇◇◇◇실 개인정보보호 분임담당자인 ◎급 ●●●은 이에 대한 확인 없이 ○○○의 개인정보 관리실태가 걱정된 것으로 전산에 등록하는 등 관련 지침을 위반하였고,

아울러, ○○○이 공단 개인정보 파일 및 비인가 프로그램(토르)을 업무용 PC에서 인터넷 망으로 전송하기 위해 승인권자에게 승인을 요청하자, ▲급 ◇◇◇은 해당 파일에 대한 확인 없이 반출을 승인함으로써, 「정보보안업무예규」 제32조(업무망 보안관리)를 위반하였다.

한편, ◇◇◇◇◇실은 2014년 이후 지속적으로 기간제 근로자를 채용해왔고 현재도 정식 연구원 외 3명의 기간제 근로자를 고용하고 있어 향후에도 이들에 대한 적절한 관리·감독이 필요하며 이에 대해 부서 전체에 주의를 환기시킬 필요성이 있다 할 것이다.

조치할 사항 이사장은,

- ① 공단 내 사용이 금지된 비인가 프로그램을 사용하여 접속이 금지된 외부 상용메일을 사용하고, 업무상 취득한 개인정보에 대해 관리를 소홀히 한 ○○○에게 엄중 ‘경고’ 조치하시기 바랍니다.(경고)
- ② 소속 기간제 근로자에 대한 관리·감독 업무를 소홀히 한 ◇◇◇◇◇실에 대해서는 ‘부서 주의’ 조치하시기 바랍니다.(부서 주의)

통 보

【 2 】

제 목 : 정보보안 관제 업무에 관한 사항
구 분 : 정보보안 관리
내 용

1. 비인가 프로그램 점검 및 보안관제 시스템에 관한 사항

공단은 「정보보안업무예규」 제25조(PC등 단말기 보안관리), 제26조(인터넷 PC 보안관리) 및 제36조(악성코드 감염 방지대책) 등에 따라, 인터넷과 연결된 PC 등의 보안 관리를 위하여 상용메신저, 웹하드, P2P¹⁵⁾ 등 보안 취약 프로그램과 비인가 프로그램 사용을 금지하고 있으며, 악성코드 등의 감염을 방지하기 위하여 관련 사이트 접속을 차단하도록 하고 있다.

그러나, 이러한 규정에도 불구하고 ▲▲▲본부는 업무용 PC 사용자의 비인가 프로그램 사용 여부에 대해 상시·주기적으로 점검, 관리하거나 또는 그 사용 행위가 발생하면 즉시 탐지·대응하는 프로세스를 갖추지 못하고 있다.

즉, 2017. 5. 18. ◇◇◇◇◇실 기간제 근로자가 공단에서 사용 금지된 상용메일 사이트에 접속하기 위하여 비인가 프로그램인 토르를 사용한 사실이 탐지되었는데, 이는 최근 사이버위기에 대응한 국가정보원의 보안정책¹⁶⁾ 강화 지침에 따라 ■■■■부에서 ‘랜섬웨어(위너크라이)’ 관련 보안관제 수행 중 우연히 탐지하였을 뿐이며, 또한 그 당시 ■■■■부는 해당 통신 트래픽이 토르에 의해 발생한 것을 인지하지는 못하고 있었다.

15) 인터넷상에서 개인과 개인이 직접 파일을 공유할 수 있는 개인 간의 접속 방식

16) 전 세계적으로 워너크라이 랜섬웨어(150여개 국가 감염피해 발생) 공격이 확산됨에 따라 이에 대비하여 국가사이버안전센터의 사이버위기 경고가 ‘관심’에서 ‘주의’단계로 상향조정됨

이와 같이 ■■■■부가 공단 내 토르 등 비인가 프로그램의 사용 여부를 파악하지 못함에 따라, 감사실은 이와 유사한 비인가 프로그램 5종¹⁷⁾을 특정하여 공단 업무용 PC에 대한 전수 조사를 의뢰하였고, 그 결과 다른 업무용 PC 1대에서 개인 간 파일공유를 목적으로 하는 비인가 프로그램(u-torrent)이 설치된 사실을 확인하였다.

《 비인가 프로그램 설치 점검 결과 》

순번	프로그램명	점검기간	설치 PC 수
1	토르(Tor Browser)	2017. 5. 22.~ 23.	0 대
2	프리넷(Free net)	2017. 6. 1. ~ 2.	0 대
3	아이투피(I2P)	2017. 6. 1. ~ 2.	0 대
4	울트라서프코프(Ultasurf Corp)	2017. 6. 1. ~ 2.	0 대
5	유토렌트(u-torrent*)	2017. 6. 1. ~ 2.	1 대

* □□지사 공익근무요원이 설치·사용한 사실 확인

이를 종합해 볼 때, ▲▲▲본부는 토르 등 비인가 프로그램의 사용이 악성코드 감염 및 자료 유출 등 정보보안에 위협이 될 수 있어 이를 금지하고 있으나, 실제로는 완벽히 통제하거나 제어하지는 못하는 것으로 판단되는 바, 비인가 프로그램 설치·사용에 대한 정기적 점검 프로세스가 필요하다.

이와 별개로 토르는 인터넷 트래픽을 암호화¹⁸⁾하여 여러 송수신 단계를 거치면서 통신하는 특성을 갖고 있기 때문에, 현재 공단의 보안 장비로 추적하기 어려운 면이 있어 이러한 암호화 트래픽을 제어하기 위한 복호화 솔루션 등 보안관제 시스템 보강이 필요한 것으로 판단된다.

17) 프리넷(Free net), 아이투피(I2P), 울트라서프코프(Ultasurf Corp)는 토르와 유사한 IP 우회 접속 프로그램이며, 유토렌트(u-torrent)는 주로 불법 복제물 유통에 쓰이는 자료공유 프로그램임

18) 트래픽 암호화는 웹 브라우저와 웹 서버 간 데이터의 내용을 알 수 없도록 한 것이며, 이로 인해 악성코드를 찾기 어려우므로 다양한 보안위협이 발생할 수 있음

2. 보안관제 매뉴얼에 관한 사항

보안관제는 사이버공격을 방어하는 제1차 단계로서, 시스템 모니터링을 통해 탐지결과를 분석하고 이 중 위협정보를 판단하여 초기에 대응함으로써 통신망과 정보시스템의 피해 발생을 차단 또는 최소화하는 역할을 수행한다.

■■■■부는 자체 「사이버위기 대응 실무 매뉴얼」¹⁹⁾에서 사이버위기 시 역할 및 업무분장, 경보 단계 및 단계별 대응요령, 공격별 시나리오 등 대책을 마련하여 운영하고 있다.

2017. 5. 18. 토르 사용에 대하여 ■■■■부는 ‘사용자 PC 이상 여부 및 피해 확인 → 보안시스템의 증거자료 분석 → 토르 프로그램 입수 → ■■■■사이버안전센터 보고 → PC 회수’ 등의 방법으로 대응하였다.

그러나, 이 과정에서 ■■■■부 담당 직원은 위협 트래픽을 최초 탐지한 17:50부터 토르를 입수한 19:01까지 상급자에게 보고 없이 단독 판단 하에 초동 조치하였으며, 그 사이 ■■■■사이버안전센터로부터 6차례의 관련 문의²⁰⁾를 받고도 자의적으로 응대한 사실이 확인되었다.

이러한 대응이 적절한지 여부는 「사이버위기 대응 실무 매뉴얼」을 기준으로 판단할 필요가 있는데, 매뉴얼의 내용은 주로 외부 공격의 위기상황과 그 대응에 대해 규정하고 있어, 이번 같은 내부 사이버위협 대응의 기준으로 미흡한 부분이 있다.

19) ■■부 매뉴얼을 근거로 사이버위기 상황 발생 시 적용할 세부 대응절차 및 제반 조치사항 등을 규정하고 있음(2017. 3. 15. 최종 개정)

20) ■■■■사이버안전센터 통화 이력

(1차 관제요원1, 5.18. 17:57) 워너크라이 랜섬웨어 감염 PC에 대한 긴급점검 요청
(2차 관제요원2, 5.18. 18:03) 감염시스템 용도 및 윈도우 보안패치 적용 유무 문의
(3차 운영직원, 5.18. 18:16) PC 점검 유무 문의
(4차 운영직원, 5.18. 18:25) 발생원인 문의
(5차 운영직원, 5.18. 18:46) 보건■■부 보고 예정
(6차 운영직원, 5.18. 19:04) 발생원인 문의

따라서, 내부 사이버위협 탐지시 보고 체계 및 시기, 초기 조사방법, PC 확인 및 즉시 회수 여부, ■■■사이버안전센터 등 관계기관 응대요령 등의 초동 조치를 포함한 내부위협 대응 매뉴얼 마련이 필요하다.

조치할 사항

이사장(▲▲▲본부장)은 내부의 사이버위협에 대응할 수 있도록 업무용 PC 내 비인가 프로그램 사용의 정기적인 점검 및 사용자 교육 강화 등 적절한 관리 방안을 마련하시고, 보안관제 시스템 및 매뉴얼의 개선을 통해 보다 실효성 있는 정보보안 체제를 구축하시기 바랍니다.(통보)